LITERATURE SURVEY

Secure CI/CD for AI Services using GitHub Actions, Trivy and tfsec

1. Introduction

A literature survey is the systematic study of previously published research related to a project. It helps understand the existing methods, technologies, findings and limitations identified by researchers. It also helps identify research gaps and establish the need for the proposed project.

The present project, "Secure CI/CD for AI Services using GitHub Actions, Trivy and tfsec," focuses on integrating automated security checking into the development lifecycle of Generative AI applications. A Generative AI-based Student Chatbot developed using Python and FastAPI and integrated with the Gemini API is considered as an example application.

The project uses Docker to package the application and its dependencies, GitHub to manage the source code, and GitHub Actions to automate the CI/CD workflow. Trivy is used to scan application dependencies and Docker images for known vulnerabilities, whereas tfsec is used to identify potential security misconfigurations in Terraform files.

This literature survey reviews two research papers related to automated vulnerability detection, container security, Trivy and CI/CD pipeline integration. It examines their contributions, limitations and relevance to the proposed project.

2. Objectives of the Literature Survey

- To understand the importance of security in CI/CD pipelines.
- To study existing research on automated vulnerability detection.
- To understand how Trivy can be integrated into GitHub Actions for container security scanning.
- To examine the importance of Shift-Left Security in software development.
- To study methods for identifying and preventing security vulnerabilities before deployment.
- To identify the research gap and establish the need for the proposed secure CI/CD pipeline for Generative AI applications.

3. Review of Related Literature

3.1 Security Regression Visualization in CI/CD Using Trivy and GitHub Actions

Authors: Yurii Zhuravchak, Danyil Zhuravchak, Anastasiia Zhuravchak and Ivan Opirskyy (2025).

This research paper presents a lightweight approach for integrating container security scanning into CI/CD pipelines using Trivy and GitHub Actions. The authors explain that security scanning is important because container images may contain vulnerabilities in operating system packages and application dependencies.

The proposed approach integrates Trivy into a GitHub Actions workflow to automatically scan Docker images during the development process. The research also introduces a method for storing

vulnerability results across multiple builds. The detected vulnerabilities are classified into four severity levels: Critical, High, Medium and Low.

The scan results are stored in a CSV file and displayed through a dashboard developed using Chart.js. This helps developers observe whether the number of vulnerabilities is increasing or decreasing across different builds.

The authors conducted an experiment using five Docker image versions containing different levels of vulnerabilities. The experiment demonstrated how removing risky packages, adding dependencies and updating base images can affect the security status of container images.

Relevance to the Present Project

This paper is highly relevant because it demonstrates the integration of Trivy with GitHub Actions for automated Docker image vulnerability scanning. The same concept is used in the proposed project to scan the Docker image and application dependencies of a Generative AI Student Chatbot. It provides a foundation for automating security checks whenever changes are pushed to the GitHub repository.

Limitations

The research mainly focuses on container vulnerability scanning and tracking security changes across builds. It does not specifically examine Generative AI applications, Gemini API integration or Terraform security scanning using tfsec.

Reference

Zhuravchak, Y., Zhuravchak, D., Zhuravchak, A., & Opirskyy, I. (2025). Security regression visualization in CI/CD using Trivy and GitHub Actions. CSDP 2025: Cyber Security and Data Protection.

3.2 Securing Container Images through Automated Vulnerability Detection in Shift-Left CI/CD Pipelines

Authors: Arvind Kumar Bhardwaj, P. K. Dutta and Pradeep Chintale (2024).

This research paper discusses the importance of automated vulnerability detection in containerized applications through Shift-Left Security practices. The authors explain that container technologies such as Docker and Kubernetes improve application portability and deployment, but they can also introduce security risks.

The paper identifies several container security challenges, including vulnerable application dependencies, insecure configurations, runtime threats, exposed credentials and container orchestration vulnerabilities.

The authors emphasize the importance of identifying security problems during the early stages of software development instead of waiting until the application is deployed. This approach is known as Shift-Left Security.

The proposed methodology integrates automated security scanning into CI/CD pipelines. It discusses the use of static and dynamic analysis tools, vulnerability databases and security policies to identify potential weaknesses.

The paper also explains that tools such as Trivy can scan container images and their dependencies. Security policies can be configured to prevent the deployment of images containing critical vulnerabilities. It further highlights the importance of continuous monitoring, vulnerability reports and remediation procedures.

Relevance to the Present Project

This research supports the main objective of the proposed project, which is to identify security vulnerabilities before deploying a Generative AI application. The concept of Shift-Left Security is applied by integrating Trivy and tfsec into the CI/CD workflow. Trivy checks application dependencies and Docker images, while tfsec examines Terraform configuration files for possible security misconfigurations.

The paper also supports the idea of configuring security policies so that the pipeline can stop when specified security conditions are not satisfied.

Limitations

The paper mainly discusses general container security and automated vulnerability detection. It does not provide a specific implementation for a Generative AI chatbot or focus on integrating tfsec with GitHub Actions. Its methodology discusses multiple CI/CD platforms, rather than providing a complete implementation of the exact tool combination used in the proposed project.

Reference

Bhardwaj, A. K., Dutta, P. K., & Chintale, P. (2024). Securing container images through automated vulnerability detection in Shift-Left CI/CD pipelines. Babylonian Journal of Networking, 2024, 162–170. https://doi.org/10.58496/BJN/2024/016

4. Comparative Synthesis of the Literature

The two research papers explain different but related aspects of security automation in software development. The first paper focuses on Trivy-based container scanning integrated with GitHub Actions and the visualization of vulnerability changes across builds. The second paper focuses on Shift-Left Security, automated vulnerability detection, policy enforcement and remediation.

Research Paper	Main Focus	Contribution to the Present Project	Limitation
Zhuravchak et al. (2025)	Trivy and GitHub Actions integration for container scanning.	Provides a practical approach for automating Docker image vulnerability scanning through GitHub Actions.	Does not focus on Generative AI applications or Terraform scanning using tfsec.
Bhardwaj et al. (2024)	Automated vulnerability detection and Shift-Left Security.	Explains early security checking, vulnerability scanning, policy enforcement and remediation in CI/CD pipelines.	Does not provide a specific implementation for a Gemini-based chatbot using GitHub Actions and tfsec.

The reviewed research establishes that automated vulnerability detection and early security checking are important for reliable software development. However, the proposed project applies

these concepts to a Generative AI application by combining application development, containerization and multiple security-checking tools in a single workflow.

5. Research Gap

The reviewed research papers provide useful methods for integrating automated security scanning into CI/CD pipelines. The first paper demonstrates how Trivy and GitHub Actions can be used for Docker image vulnerability scanning and security regression tracking. The second paper explains the importance of Shift-Left Security, automated vulnerability detection and policy enforcement.

However, the reviewed papers mainly focus on general software applications and container security. They do not specifically demonstrate a complete security-checking workflow for a Generative AI-based application that combines a chatbot, Docker, GitHub Actions, Trivy and tfsec.

Therefore, the identified research gap is the application of these security automation techniques to a Generative AI service while checking both application/container vulnerabilities and infrastructure configuration risks.

6. How the Present Project Addresses the Research Gap

The proposed project, "Secure CI/CD for AI Services using GitHub Actions, Trivy and tfsec," addresses the identified gap through the following approach:

- Generative AI Application: A Student Chatbot developed using Python and FastAPI and integrated with the Gemini API is used as the example application.
- Docker Containerization: Docker packages the chatbot and its required dependencies into a Docker image.
- GitHub Integration: GitHub stores and manages the project source code.
- Automated CI/CD: GitHub Actions executes the configured workflow whenever changes are pushed to the repository.
- Dependency and Container Scanning: Trivy scans application dependencies and Docker images to identify known security vulnerabilities.
- Infrastructure Security Scanning: tfsec examines Terraform configuration files to identify potential security misconfigurations.
- Security Validation: The workflow can be configured to stop when security findings exceed the defined severity or policy threshold, allowing developers to investigate and fix the issues before proceeding.

By combining these tools, the project demonstrates how automated security checking can be integrated into the development lifecycle of Generative AI applications.

7. Conclusion

The literature survey shows that automated security scanning plays an important role in modern software development. The first research paper demonstrates the use of Trivy and GitHub Actions for container vulnerability scanning and tracking security changes across builds. The second

research paper explains Shift-Left Security and the importance of detecting and fixing vulnerabilities during the early stages of the development lifecycle.

Based on these studies, the proposed project applies automated security checking to a Generative AI Student Chatbot. It combines Docker, GitHub Actions, Trivy and tfsec to identify potential vulnerabilities in application dependencies, container images and Terraform configurations.

The main objective is to reduce manual security-checking effort, identify possible risks before deployment and improve the reliability of Generative AI application development.

8. References

1. Zhuravchak, Y., Zhuravchak, D., Zhuravchak, A., & Opirskyy, I. (2025). Security regression visualization in CI/CD using Trivy and GitHub Actions. CSDP 2025: Cyber Security and Data Protection.

2. Bhardwaj, A. K., Dutta, P. K., & Chintale, P. (2024). Securing container images through automated vulnerability detection in Shift-Left CI/CD pipelines. Babylonian Journal of Networking, 2024, 162–170. https://doi.org/10.58496/BJN/2024/016